



Chapitre I Introduction Secure Programming

Kebsi Nozha
ISG-2022

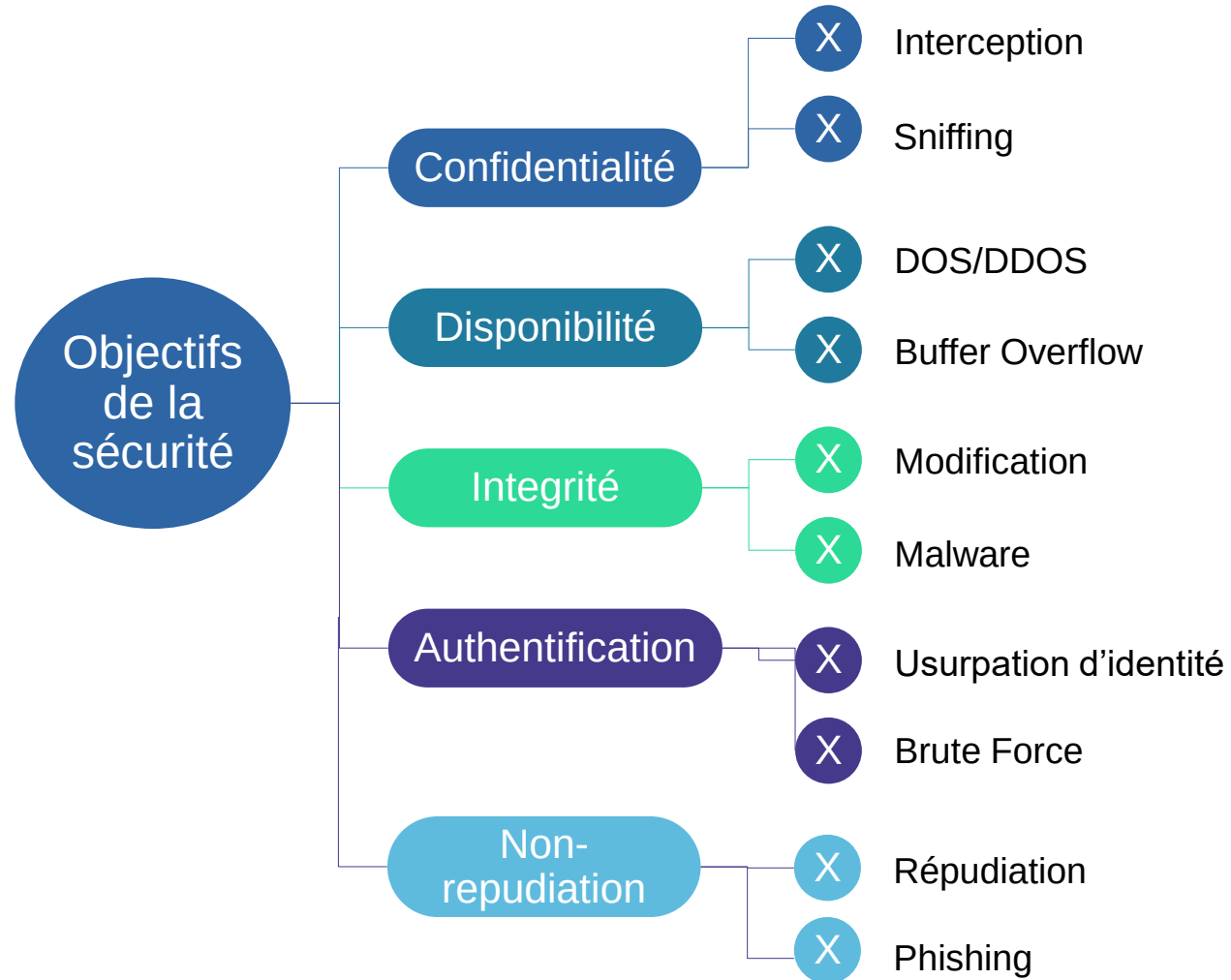
Objectifs

L'objectif de ce cours est de présenter un ensemble de bonnes pratiques pour développer un logiciel/application de façon sécurisée grâce à la compréhension de la nature des vulnérabilités principales liées au développement logiciel.

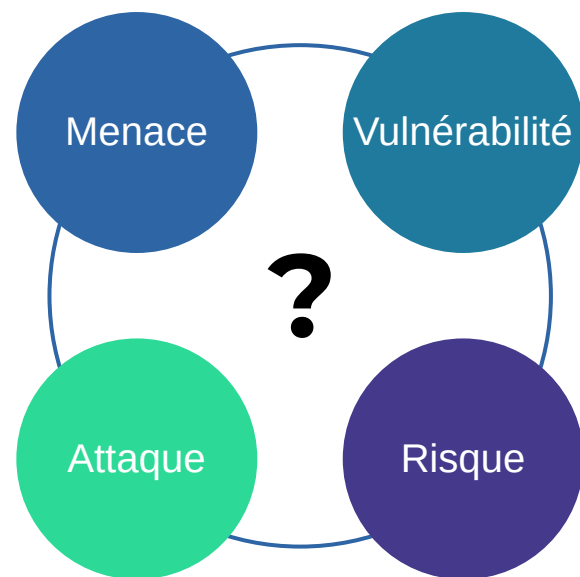
À la fin du cours, les étudiants devraient:

- ✓ Comprendre les enjeux du développement sécurisé;
- ✓ Connaître les menaces courantes;
- ✓ Avoir acquis des réflexes et des bonnes pratiques;
- ✓ Intégrer la sécurité au plus tôt dans le développement logiciel;
- ✓ Avoir développé un esprit critique pour s'adapter aux nouvelles menaces.

Rappel



Definitions 1



- **Menace** : Une personne, un objet, ou un évènement pouvant provoquer des dommages sur un système et ayant un impact sur ses fonctionnalités, son intégrité ou sa disponibilité.
- **Vulnérabilité** : Faiblesse pouvant être exploitée par une ou plusieurs menaces
- **Attaque** : Action compromettant la sécurité de l'information d'une organisation.
- **Risque** : quantité ou qualificatif exprimant la possibilité qu'une attaque soit réalisée sur une ressource en exploitant les vulnérabilités qu'elle présente.

Definitions 2



Common Vulnerabilities and Exposures

- Un dictionnaire des informations publiques relatives aux vulnérabilités de sécurité qui permet d'identifier, de définir et de cataloguer les vulnérabilités de cybersécurité divulguées publiquement
- Le dictionnaire est maintenu par l'organisme MITRE, soutenu par le département de la Sécurité intérieure des États-Unis.
- Les identifiants CVE sont des références de la forme CVE-AAAA-NNNN (AAAA est l'année de publication et NNNN un numéro d'ic

2019	2018	2017	2016
1. CVE-2018-15982	1. CVE-2018-8174	1. CVE-2017-0199	1. CVE-2016-0189
2. CVE-2018-8174	2. CVE-2018-4878	2. CVE-2016-0189	2. CVE-2016-1019
3. CVE-2017-11882	3. CVE-2017-11882	3. CVE-2017-0022	3. CVE-2016-4117
4. CVE-2018-4878	4. CVE-2017-8750	4. CVE-2016-7200	4. CVE-2015-8651
5. CVE-2019-0752	5. CVE-2017-0199	5. CVE-2016-7201	5. CVE-2016-0034
6. CVE-2017-0199	6. CVE-2016-0189	6. CVE-2015-8651	6. CVE-2016-1010
7. CVE-2015-2419	7. CVE-2017-8570	7. CVE-2014-6332	7. CVE-2014-4113
8. CVE-2018-20250	8. CVE-2018-8373	8. CVE-2016-4117	8. CVE-2015-8446
9. CVE-2017-8750	9. CVE-2012-0158	9. CVE-2016-1019	9. CVE-2016-3298
10. CVE-2012-0158	10. CVE-2015-1805	10. CVE-2017-0037	10. CVE-2015-7645

Definitions 3

Common Weakness Enumeration



- Décrire et discuter des faiblesses logicielles et matérielles dans un langage commun.
- Vérifiez les faiblesses des produits logiciels et matériels existants.
- Évaluer la couverture des outils ciblant ces faiblesses.
- Prévenir les vulnérabilités logicielles et matérielles avant le déploiement.

Rank	ID	The CWE Top 25 Name	Score	KEV Count (CVEs)	Rank Change vs. 2021
1	CWE-787	Out-of-bounds Write	64.20	62	0
2	CWE-79	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	45.97	2	0
3	CWE-89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	22.11	7	+3 ▲
4	CWE-20	Improper Input Validation	20.63	20	0
5	CWE-125	Out-of-bounds Read	17.67	1	-2 ▼
6	CWE-78	Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')	17.53	32	-1 ▼
7	CWE-416	Use After Free	15.50	28	0
8	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	14.08	19	0
9	CWE-352	Cross-Site Request Forgery (CSRF)	11.53	1	0
10	CWE-434	Unrestricted Upload of File with Dangerous Type	9.56	6	0

Definitions 4

Common Vulnerability Scoring System



Permet de saisir les principales caractéristiques d'une vulnérabilité et de produire un score numérique reflétant sa gravité. Le score numérique peut ensuite être traduit en une représentation qualitative (telle que faible, moyen, élevé et critique) pour aider les organisations à évaluer et à hiérarchiser correctement leurs processus de gestion des vulnérabilités.

Base Score

7.1
(High)

Attack Vector (AV)

Network (N) Adjacent (A) Local (L) Physical (P)

Attack Complexity (AC)

Low (L) High (H)

Privileges Required (PR)

None (N) Low (L) High (H)

User Interaction (UI)

None (N) Required (R)

Scope (S)

Unchanged (U) Changed (C)

Confidentiality (C)

None (N) Low (L) High (H)

Integrity (I)

None (N) Low (L) High (H)

Availability (A)

None (N) Low (L) High (H)

OWASP SCP (Secure Coding Practices):

La référence de pratiques de codage sécurisé (SCP) de l'OWASP est une liste de contrôle orientée vers les développeurs qui vise à améliorer le développement sécurisé des applications.

Il faut vérifier par rapport à chaque élément de la liste afin d'identifier les faiblesses et les domaines qui doivent être traités.

En adoptant les pratiques de ce guide, vous pouvez éviter les failles courantes et renforcer vos applications contre les attaques. Après avoir abordé chaque élément de la liste de contrôle, vous serez rassuré quant à la sécurité globale.

Introduction	3
Software Security and Risk Principles Overview	4
Secure Coding Practices Checklist	5
Input Validation:	5
Output Encoding:	5
Authentication and Password Management:	6
Session Management:.....	7
Access Control:.....	8
Cryptographic Practices:.....	9
Error Handling and Logging:	9
Data Protection:.....	10
Communication Security:	10
System Configuration:.....	11
Database Security:	11
File Management:.....	12
Memory Management:	12
General Coding Practices:.....	13

OWASP ASVS (Application Security Verification Standard)

Un cadre d'exigences qui se concentrent sur la définition des contrôles de sécurité fonctionnels et non fonctionnels requis lors de la conception, du développement et du test des applications.

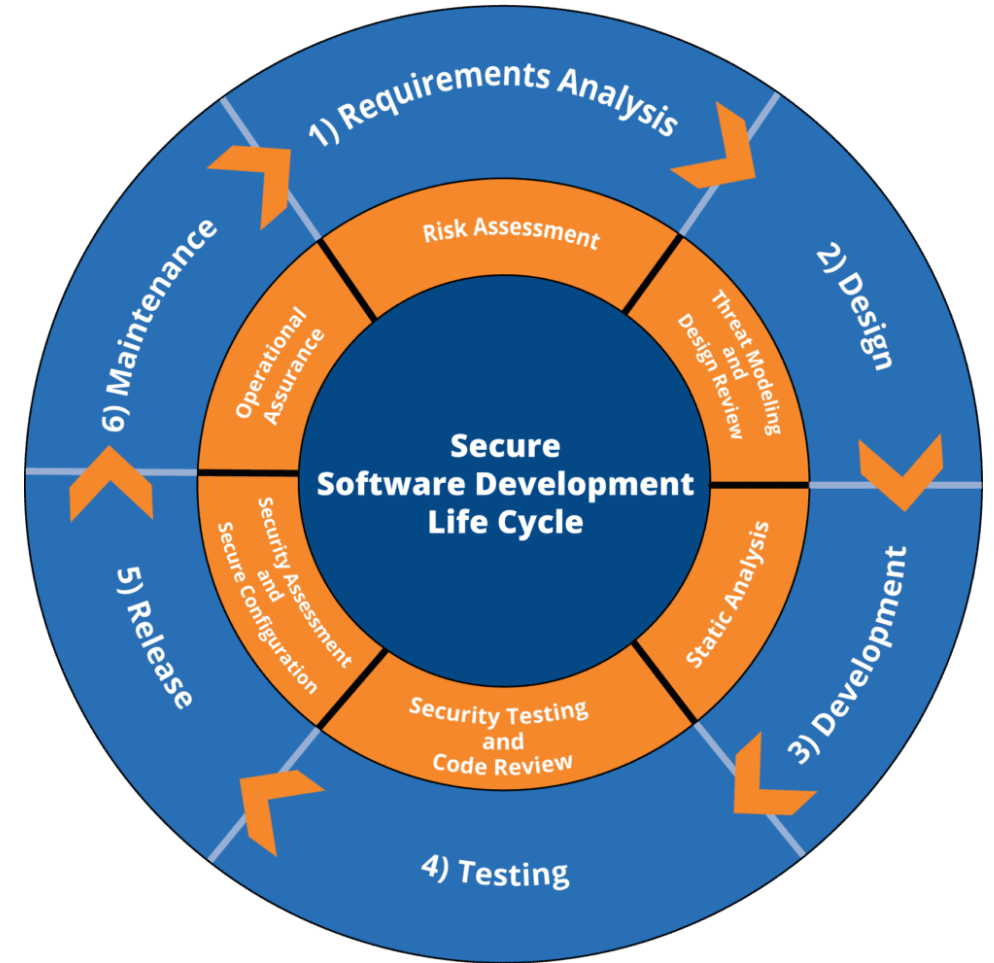
- V1 Architecture, conception et exigences en matière de modélisation des menaces
- V2 Authentification
- V3 Exigences de vérification de la gestion des sessions
- V4 Exigences de vérification du contrôle d'accès
- V5 Exigences de validation, d'assainissement et de vérification de l'encodage
- V6 Exigences de vérification de la cryptographie stockée
- V7 Traitement des erreurs et exigences de vérification de l'enregistrement
- V8 Exigences de vérification de la protection des données
- V9 Exigences de vérification des communications
- V10 Exigences de vérification des codes malveillants
- V11 Exigences de vérification de la logique d'entreprise
- V12 Exigences de vérification des dossiers et des ressources
- V13 Exigences de vérification des API et des services Web
- V14 Exigences de vérification de la configuration

Cycle de vie de développement logiciel sécurisé (SSDLC)

Secure Software Development Lifecycle

Le processus de développement de logiciels sécurisés est un ensemble de meilleures pratiques basées sur des documents de développement de logiciels sécurisés éprouvés provenant d'organisations leaders du secteur telles que OWASP ou SAFECode.

Également appelé cycle de vie de développement logiciel sécurisé (SSDLC), il vise à renforcer la sécurité par rapport au SDLC standard et à garantir la protection du produit final.





Thank You
For Your Attention